

Last time we've seen Telnet. It can be used for two tasks:

1. Connect to the Telnet port, 23. However, it's not secure as a service, and it's preferred to use SSH.
2. ?

There are different cases in which Telnet should be used. For example, old organisations may still use it. So, to make it secure, we need to use a firewall, allowing Telnet connections only to specific source addresses. Or maybe, through a VPN.

One of the weaknesses of Telnet is that it sends a banner when opening a connection.

One other dimension of Telnet is that the Telnet client can be used as an useful tool for enumeration, regardless if the port is open or not. The attacker can use Telnet to interact with other services, like the mail server, web server, etc.

Another important service that we have to consider is SMTP server, port 25. It's the mail server. The SMTP protocol can be enumerated using the Telnet client. This port should be open, as it's necessary to receive e-mails.

Two commands for the SMTP server are important: the first is the `verify` command, used to check if a given e-mail address is valid or not; the second is the `EXPN` protocol, it can be used sending an e-mail alias to a destination mailer, and asking if it corresponds to one user inside the destination organisation.

Note that these commands are part of the protocol and not vulnerabilities.

What is the countermeasure? Authentication. These two commands will be disabled for anyone who's not authenticated.

Next service is DNS, port 53. We've already seen that DNS can be used for footprinting, but also for enumeration. The weakness is the same, zone transfer. It's used by network administrators to create backups of the DNS server.

Since DNS server contains the mapping between hostname and physical IP address, it's ideal for enumeration. Usually, hackers do a dump of the DNS of the target organisation, then studying it. Zone transfers can be restricted only to some specific network machines. Commands like `nslookup` can be used to perform the zone transfer.

Another attack is DNS cache snooping. It's a feature actually of the DNS protocol. The DNS protocol will use local cache information. With the `norecurse` option,

we can ask DNS servers only to search for information locally, and if the info is not there then the answer will respond with a negative answer.

As for the tools for enumeration, we can use `dnsenum`.

As a countermeasure, we should divide the DNS into internal and external servers, blocking and restricting zone transfers, and restricting DNS queries to limit cache snooping.

Another service is given by TFTP, port 69, running on either TCP or UDP. It's an old service, used for network devices administration. It's a File Transfer Protocol (FTP), but highly insecure. One command we can run is `get`, through which we read a file from the destination. We can see that there is no authentication, while in the standard FTP protocol username and passwords needs to be provided.

The authentication is actually given by the name of the file.

Countermeasures are given by wrapping it to restrict accesses, using a tool as a TCP wrapper (acting as a basic local firewall), allowing only certain clients to access a service.

Then, we have Finger, port 79. It gives information about the users using the machine, which accounts are logged. We can get information about the idle time for users, giving real time information.

HTTP is the next one, port 80. We can first grab banners with `telnet` and `netcat`. When using SSL-enabled websites, we use `sslproxy` or use SSL client `openssl`.

HTTP could be problematic, as it needs to be open.

Basic countermeasures: change the banner on our webserver, with tools like MS URLScan.

*Expand a bit this section.*

So far we've seen services that are both on Linux and Windows.

There are some well-known running on Windows platform only, however.

One of them is given by Microsoft RPC Endpoint Mapper (MSRPC), port 135. If this port is open, we can see the OS running the service is obviously a Windows machine.

It helps in handling distributed services through remote procedure calls (RPC). To implement this service, we'll have a master service, which will know all the possible remote services which can be invoked with an RPC. Querying this service can give information about applications and services available on the target

machine.

There is a tool to do this, `epdump`. It shows services bound to IP addresses.

For the countermeasures, we have the blocking of the port with a firewall.

However, this is not enough. There are some microsoft services needing this port, like the Microsoft Exchange Server, used for mails. By definition, this mailer is external to the perimeter. Thus, we need this port to be open in the end.

One solution is to use a VPN, so that the mailer that is outside will open a VPN connection with the inside of the organisation, and then connect to the service.

One other solution is to update to the version of the Outlook Web Access, using HTTPS.